

HACKING METHODOLOGY - detailed notes

• hacking methodology

A structured sequence of phases used to discover, test, and exploit security weaknesses - used by attackers and mirrored by ethical hackers to improve defenses.



Phases (with purpose s outcomes)

1. Planning s Rules of Engagement

- Purpose: Agree scope, legal limits, success criteria, and reporting.
- Typical outcomes: signed authorization, scope list (IPs, domains), exclusion list, test windows, contact persons, safe-word/kill-switch.

- c. Defensive notes: If you manage assets, make sure you know what external testers will probe — it prevents misinterpretation of scanning alerts.
- 2. Reconnaissance / Footprinting**
- a. Purpose: Build a low-noise map of the public attack surface and contextual information (people, tech).
 - b. Outputs: inventory of domains/subdomains, public IP blocks, technology fingerprints, list of exposed services and potential social targets.
 - c. Defensive notes: Public exposure monitoring (brand monitoring, repo scanning) substantially lowers surprise.
- 3. Scanning**
- a. Purpose: Confirm which hosts and services are reachable and gather service-level details.
 - b. Outputs: live-host lists, open ports, banners (service names/version), possible OS families.
 - c. Defensive notes: Frequent, authorized internal scanning prevents surprise and reduces noisy external scans.
- 4. Enumeration**
- a. Purpose: Collect specific data about services and identities (usernames, share names, directory structure).
 - b. Outputs: lists of user accounts, directory shares, accessible endpoints, misconfigurations.
 - c. Defensive notes: Limit anonymous enumeration (e.g., LDAP/SMB) and monitor for unusual queries.
- 5. Vulnerability Analysis**
- a. Purpose: Match discovered services/configurations to known weaknesses and prioritize risk.
 - b. Outputs: prioritized vulnerability list (with context: exposure, exploitability, business impact).
 - c. Defensive notes: Prioritization must factor business criticality — a medium CVE on payroll server may be higher risk than a high CVE on an isolated test system.
- 6. Gaining Access (Exploitation) — conceptual**
- a. Purpose: Convert vulnerabilities into footholds. (Defenders: understand common attacker goals to spot indicators.)
 - b. Outputs: proof-of-concept demonstrating viability (safely reported), evidence artifacts for defenders to detect.
 - c. Defensive notes: Detection engineering should look for patterns of exploitation (sudden new processes, abnormal network connections).

7. Post-Exploitation s Maintaining Access

- a. Purpose: Expand control, gather valuable data, establish persistence for long-term presence.
- b. Outputs: lateral movement paths, credentials harvested, evidence of data access.
- c. Defensive notes: Robust EDR, strict logging, and privileged account monitoring are crucial.

8. Covering Tracks / Cleanup

- a. Purpose: Attempt to erase or obfuscate traces of activity to delay detection.
- b. Outputs: altered logs, deleted artifacts, unusual time gaps in telemetry.
- c. Defensive notes: Immutable and offsite logging plus integrity checks make tampering harder.

G. Reporting s Remediation

- a. Purpose: Deliver understandable reports (exec + technical) and remediation guidance.
- b. Outputs: prioritized remediation plan, timeline, retest schedule.
- c. Defensive notes: Treat reports as learning tools — include detectable indicators and recommended detection rules.

1. Footprinting

Goals s mindset

- Build a picture of the target that answers: *what is visible? who works there? what technologies are used? what third parties are involved?*
- Footprinting is reconnaissance — the attacker’s homework. Defenders should monitor and reduce this “surface.”

Passive sources (non-intrusive)

- **WHOIS s domain records** — registrant contacts, name servers.
- **DNS records** — A (IP), AAAA, MX (mail), TXT (SPF/DMARC), NS, SRV.
- **Certificate transparency logs** — certs issued for subdomains reveal subdomain names.

- **Search engines / cached pages** – archived pages or forgotten endpoints.
- **Job postings / LinkedIn** – expose technologies, software stacks, employee names or roles.
- **Public code repos (GitHub/GitLab)** – accidentally committed secrets or config files.
- **Paste sites / leak search engines** – exposed credentials or code.
- **Public cloud resource listings / S3 buckets** – misconfigured buckets or public snapshots.
- **Social media s press releases** – product names, partner names, MCA info.
- **Third-party vendor sites** – integrations that might expose APIs or data flows.

Active footprinting (noisy; needs permission)

- **DNS queries / zone transfers** – may reveal full DNS content.
- **HTTP(S) requests** – discover hidden directories, robots.txt, sitemap.xml.
- **Certificate probing** – query TLS endpoints for detailed cert chains.
- **Banner grabs** – request service banners to see product/version info.

Practical defensive actions

- Remove secrets from code repositories immediately and rotate credentials.
- Use privacy/WHOIS protection on domains where acceptable.
- Implement DNS and certificate monitoring – get alerts when new subdomains are published.
- Monitor job postings and public mentions for technology disclosure; treat carefully when listing critical tech.

2. Scanning

What scanning reveals and common approaches

- **Host discovery:** ICMP ping, ARP scans on local networks, SYN/ACK heuristics for firewalled hosts.

- **Port scans:** TCP SYN/Connect scans, UDP scans for datagram services.
- **Service/version detection:** Banner analysis, protocol handshakes, fingerprinting modules that parse response formats.
- **OS fingerprinting:** TCP/IP stack behavior, TTL and window size heuristics.
- **Vulnerability scanning:** Match service/version to vulnerability databases (CVE, NVD) and plugin lookups.

Defensive signals that scanning is happening

- Repeated short-interval connections to many ports/IPs from a single source.
- SYN scans generating half-open TCP sessions.
- High rate of failed connection attempts across diverse ports.
- Web application fuzzing patterns (many 404s for common paths, odd query params).

Defensive controls

- **Network-level:** Limit exposure via firewall rules and restrict management interfaces to VPNs or jump hosts.
- **Detection:** Use IDS/IPS signatures tuned to scanning patterns; investigate unusual connection spikes.
- **Honeypots:** Place decoy systems to detect and analyze scanning behavior.
- **Rate limiting and blacklists:** Temporarily throttle or block IPs with scanning patterns, but maintain a process for false positives (e.g., security scanners).

3. Enumeration

Typical enumeration targets s why they matter

- **Directory services (LDAP/Active Directory):** lists of users, groups, trusts, and domain controllers — gives a roadmap for privilege escalation.
- **Network shares (SMB/NFS):** accessible files or misconfigured shares often contain credentials or config files.

- **Email servers (SMTP/IMAP):** open relays, misconfigurations, or metadata that reveal internal addresses.
- **DNS zone transfers:** full DNS data that can list all subdomains and hostnames.
- **SNMP:** default community strings often reveal device configurations and network maps.

Defensive best practices

- Limit directory service queries to authenticated clients; apply ACLs.
- Disable anonymous LDAP queries and anonymous SMB enumeration.
- Harden email servers to block open relays and require auth for internal operations.
- Audit and rotate SNMP community strings; restrict SNMP to management networks.

4. Vulnerability analysis

How to perform a meaningful vulnerability analysis

1. **Collect context:** which hosts are internet-facing? which store sensitive data?
2. **Map findings to business impact:** payroll servers, customer DBs, and production controllers carry higher risk.
3. **Check exploitability:** is a public exploit available? Is authentication required? Does it require user interaction?
4. **Calculate risk score:** blend CVSS with business impact, exploitability, and exposure.
5. **Recommend fixes:** configuration changes, patches, compensating controls (network segmentation, detection rules).

Example prioritization rubric

- **Critical (fix immediately):** Internet-facing service + public exploit + sensitive data exposure.
- **High:** Internal critical server + high-severity CVE + reachable by many users.
- **Medium:** Low exploitability or no known exploit but serious if chained with other flaws.

- **Low:** Minor misconfig or informational issue.

Mitigations mapped to vulnerability types

- **Config issues:** standardize baselines; use CIS benchmarks.
- **Auth flaws:** implement MFA, enforce password policies, limit admin accounts.
- **Software bugs:** apply vendor patches; use WAFs or virtual patching if immediate patching impossible.
- **Injection s business logic flaws:** validate input server-side; adopt secure design and SAST/DAST.
- **Supply chain:** track dependencies, apply SBOM (software bill of materials), and monitor advisories.

5. System hacking

For each attacker stage, defenders should know likely indicators and appropriate responses.

1. Initial reconnaissance / access attempts

- a. Indicators: phishing emails, abnormal authentication attempts, unexpected RDP/SSH connections.
- b. Response: email filtering, phishing training, rate-limit login attempts, disable legacy auth.

2. Foothold s persistence

- a. Indicators: creation of new accounts, scheduled tasks with odd names, startup entries.
- b. Response: monitor account creation events, baseline autoruns, EDR alerts for new persistence mechanisms.

3. Privilege escalation

- a. Indicators: unusual use of privilege escalation tools, sudden admin privilege grants, access to secrets vaults.
- b. Response: just-in-time admin access, remove local admin rights, apply patching for known escalation CVEs.

4. Lateral movement

- a. Indicators: internal scanning from a formerly client host, SMB/WinRM attempts, unexpected admin tool usage.
 - b. Response: internal segmentation, block unnecessary ports, monitor and alert on remote management usage.
- 5. Objective execution (data theft, ransomware)**
- a. Indicators: large outbound data transfers, encryption of many files, exfiltration channels to unusual domains.
 - b. Response: DLP, rate-limit outbound connections, identify exfil paths, isolate affected hosts quickly.
- 6. Cleanup / anti-forensics**
- a. Indicators: log deletion events, manipulation of forensic tools, abnormal time patterns in logs.
 - b. Response: immutable logging, remote log shipping, forensic snapshot before remediation.